

WEEKLY PROGRESS REPORT

Week 5: Evasion Tactics, L7 DPI Heuristics & IPS Performance Optimization

Lê Quý Tôn

May 04, 2026

Project: CyberSec Internship - Cygnus-Security
Related Issues: #28

1. Contribution Scope

This report details the evaluation of the Machine Learning (ML) classifier against advanced evasion techniques and the implementation of a deterministic Deep Packet Inspection (DPI) safety net. Furthermore, it covers critical system optimizations, including Gateway CPU load reduction and the handling of out-of-band IPS execution latency (Race Conditions).

2. Objectives of This Week

- Evaluate ML limitations against Micro-slicing, Low & Slow, and Randomization attacks.
- Implement an L7 DPI Heuristic Override to mitigate ML False Negatives.
- Optimize Suricata log parsing to halve CPU consumption during volumetric attacks.
- Implement a Graceful Shutdown mechanism to prevent persistent network lockouts.

3. Detailed Work

3.1 Description

During simulated evasion attacks, the ML model occasionally misclassified heavily obfuscated payloads (e.g., short randomized strings or artificially elongated micro-sliced domains). To comply with the project's focus on DPI, a deterministic heuristic layer was added to override ML decisions based on physical DNS constraints.

3.2 Design / Method

L7 Heuristic Override:

A strict mathematical boundary was established. If a domain bypassed the ML model but

exhibited characteristics of evasion ($\text{Entropy} \geq 4.2$ AND $\text{Length} \geq 30$, OR $\text{Length} \geq 60$), the DPI engine forces an override, flagging it as malicious.

Execution Latency Analysis & Fail-safe:

Fast-flooding simulations revealed a $\sim 150\text{-}250\text{ms}$ delay between packet detection and `iptables` enforcement. This was documented as an acceptable trade-off for an Out-of-Band architecture. Additionally, Python `try...except KeyboardInterrupt` blocks were integrated to flush `iptables` rules automatically upon system termination.

3.3 Implementation

- Updated the Python listener to explicitly filter `query_type` in `["query", "request"]`, ignoring DNS responses to save 50% CPU load.
- Wrote `evasion_simulator.sh` utilizing bash background processes (`&`) to simulate high-speed concurrent exfiltration.

4. Results / Output

- The Hybrid System successfully blocked 100% of Fast Flooding attacks, utilizing the DPI Heuristic Override for payloads that the ML classifier missed.
- The Graceful Shutdown mechanism reliably restored network connectivity when the IPS was taken offline, ensuring high availability.

5. Analysis

The week's findings underscore the necessity of a layered defense. Machine Learning provides dynamic, high-speed classification, but it possesses statistical blind spots. By anchoring the ML with deterministic L7 DPI rules, the system achieves near-perfect detection. Additionally, observing the Race Condition highlighted the physical limits of Out-of-Band IPS: while a few packets may leak during the execution delay, the architecture successfully protects the Gateway from being bottlenecked by inline packet inspection.

6. Issues & Fixes

- **Issue:** Duplicate ML processing for the same query.
- **Fix:** Filtered Suricata JSON outputs to exclusively parse `type == request`.
- **Issue:** “Zombie” `iptables` rules blocking legitimate IPs after shutting down the Python script.
- **Fix:** Implemented SIGINT Graceful Shutdown to dynamically delete specific Drop rules.
- **Issue:** ML model bypassed by Randomization (False Negatives).
- **Fix:** Calibrated and deployed the DPI Heuristic Override threshold ($\text{Entropy} \geq 4.2$).

7. Reusable Content ★

(Out-of-Band IPS Latency & Race Conditions)

When designing an Out-of-Band (Log-based) IPS, engineers must account for the “Execution Latency Chain.” The process of sniffing a packet, writing to a log, parsing via Python, calculating ML predictions, and executing a kernel-level `iptables` command inherently takes between 150ms to 300ms.

During high-speed volumetric attacks, packets arriving within this latency window will bypass the firewall before the drop rule is fully enforced. This is not a software bug, but a physical architectural trade-off: sacrificing inline precision (which causes severe network bottlenecks) for maximum Gateway throughput and stability.

8. Next Step (Future Work)

- Continue exploring advanced Evasion techniques (e.g., extremely short subdomains) to fully harden the DPI logic.
- Transition from backend engineering to frontend development by building a visual Dashboard using **Streamlit**.